MALWARE ANALYSIS

Faculdade de Tecnologia Impacta
Segurança Cibernética

Relatório Técnico de Análise de Malware

Trojan Sinowal

São Paulo

Sumário

I. Apresentação
II. Resumo executivo
III. Montagem do laboratório
IV. Identificação da ameaça
V. Resultados da análise
    - Engenharia reversa
    - Análise estática
    - Análise dinâmica
VI. Mapeamento do MITRE ATT&CK
VII. Impacto potencial
VIII. Medidas de mitigação
IX. Conclusão
X. Referências

1. Apresentação

Malware investigado: Trojan Sinowal
Analista responsável: Mauricio Robert
Organização: Faculdade impacta
Data: 11/2025

2. Resumo Executivo

O Sinowal é classificado como um Trojan Ladrão de Senhas (PWS) e é notório por ser um banking trojan complexo com arquitetura modular e capacidades de rootkit. Foi uma das ameaças mais significativas no roubo de credenciais bancárias e financeiras, atuando globalmente.

3. Montagem do Laboratório

A análise foi conduzida em um laboratório em uma V.M. isolado e controlado, seguindo as boas práticas de segurança.
Ferramentas utilizadas:
ISO:https://archive.org/download/win-10-1803-english-x-64/Win10_1803_English_x64.iso
Estática: PEStudio, Virus Total e CAPA
Dinâmica: Procmon, Process Explorer, Wire Shark, TCPView, ApateDNS e Autoruns
Engenharia reversa: IDA, PE-bear
Assinatura: Windows Defender History

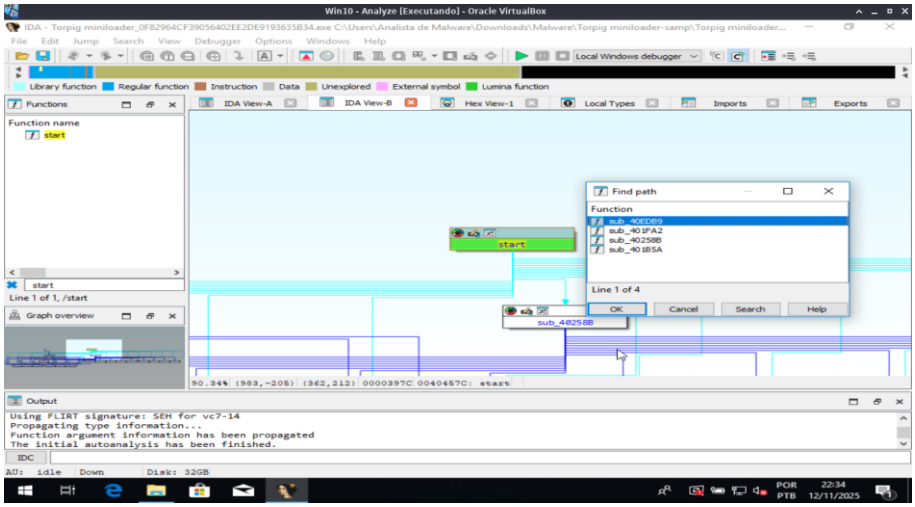
4. Identificação da Ameaça

- Nome da família: Trojan Sinowal ou Torpig
- Classificação: Trojan, Password Stealer, Backdoor
- Hash256: d59212d8eec533ecfebafda9f3b129799f8b56ea5fc11c54005bc4f359c7d2cf
- Primeira Captura: 12/2007
- Nível de risco: Alto/Crítica

5. Resultado da Análise

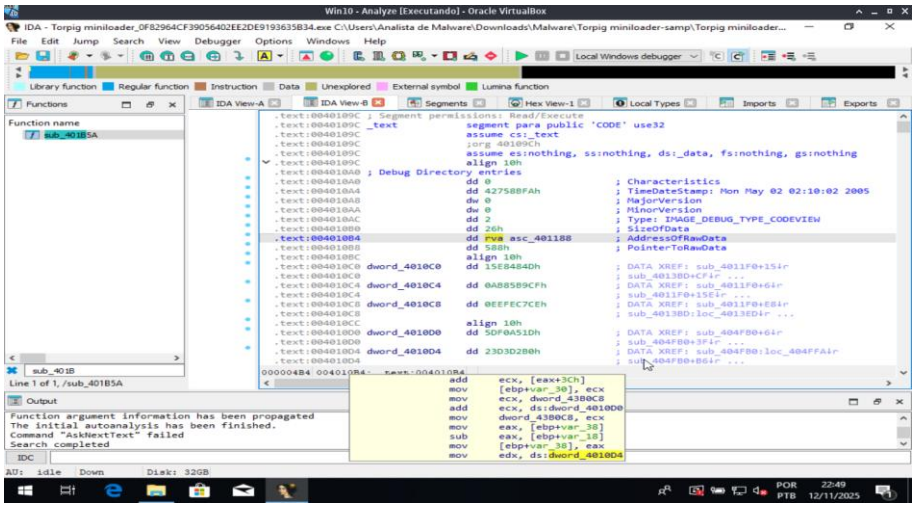
a. Engenharia Reversa

Função *Start* e suas rotinas *sub*_x - A imagem apresenta a função *Start*, que corresponde ao ponto de entrada padrão do arquivo Torpig. Onde também é possível observar diversas sub_x rotinas, as quais estão vinculadas às funcionalidades internas do malware.



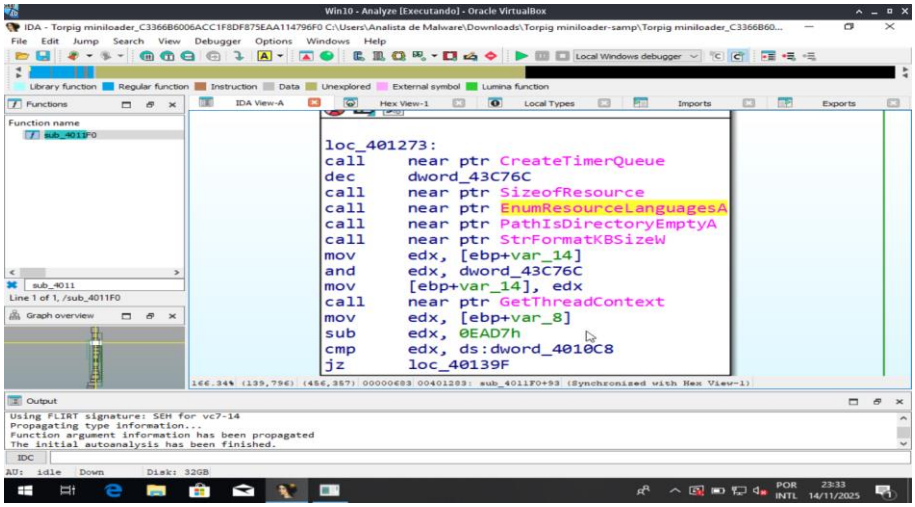
Start

RVA - Aqui mostra a função RVA, que é utilizada como loader de memória pelo sistema operacional.



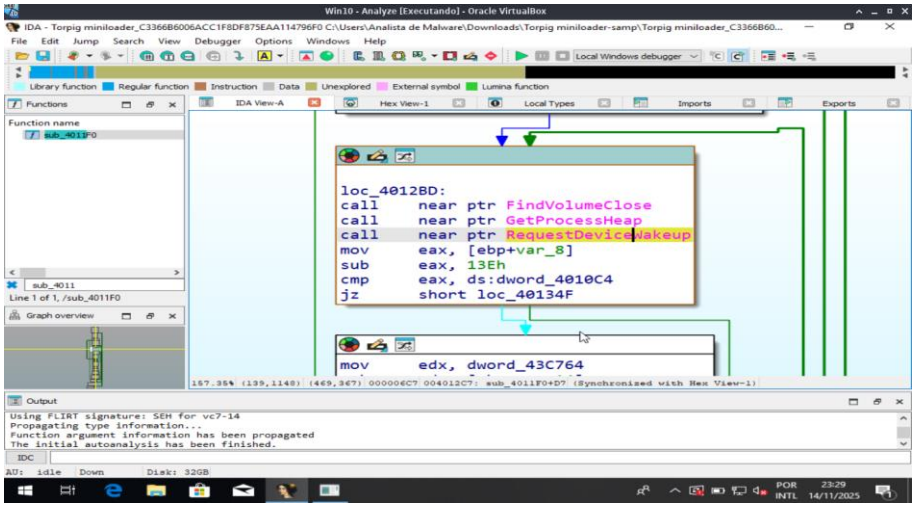
RVA

Enumeração de Idiomas - Uma função que permite o malware enumerar os idiomas dentro de espaços específicos do arquivo.PE.



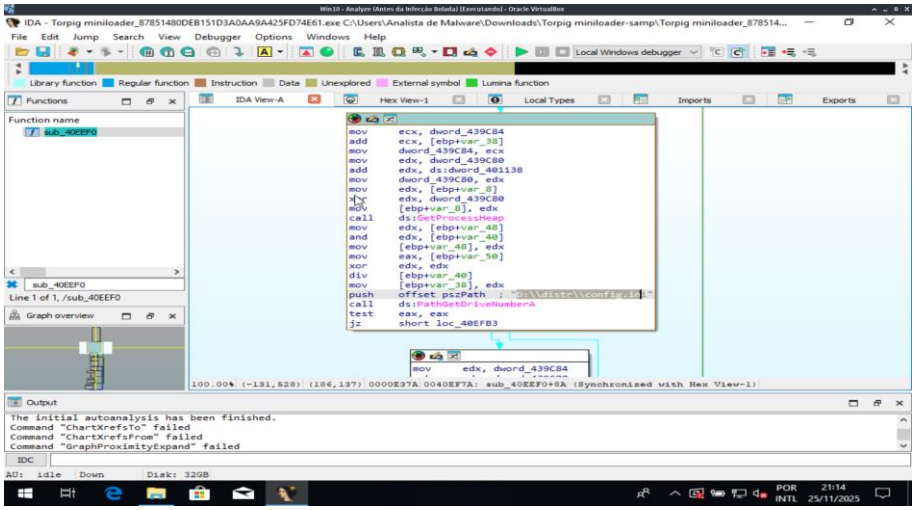
API EnumResorceLanguagesA

Função "Acordar" - Esta função é utilizada pelo sistema operacional, faça o sistema "acordar" após sua suspensão, quando um evento ocorrer.



API RequestDeviceWakeup

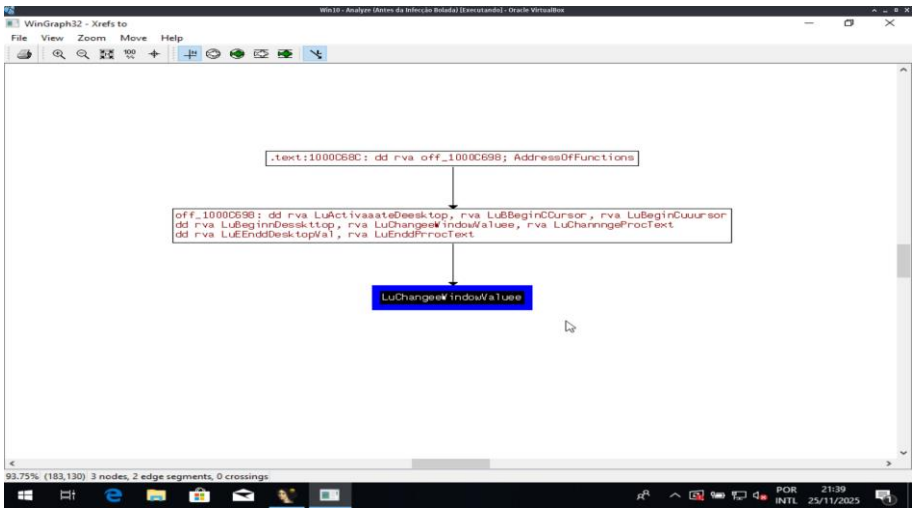
D:\.ini - Nesta imagem mostra um caminho D:\ .ini, sendo um possível método de reconhecimento de disco ou arquivo temporário, podendo conter arquivos temporários e configurações.



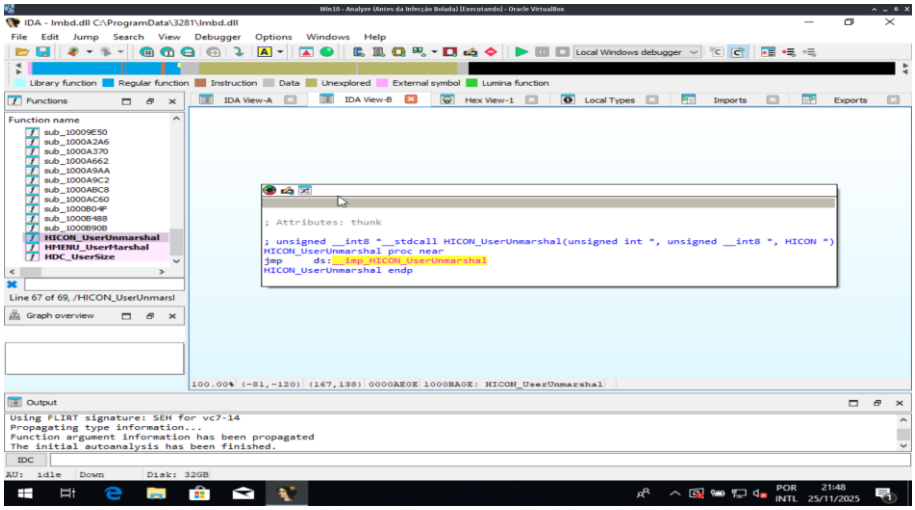
D:

Keylogger – As imagens apresentam **APIs relacionadas a mecanismos de ofuscação e desofuscação**, além de rotinas que sugerem comportamentos associados à **captura de eventos de teclado ou interação com o foco da janela**. Entre as funções destacadas estão:

- **LuChangeWindowValue**
- **imp_HICON_UserUnmarshal**

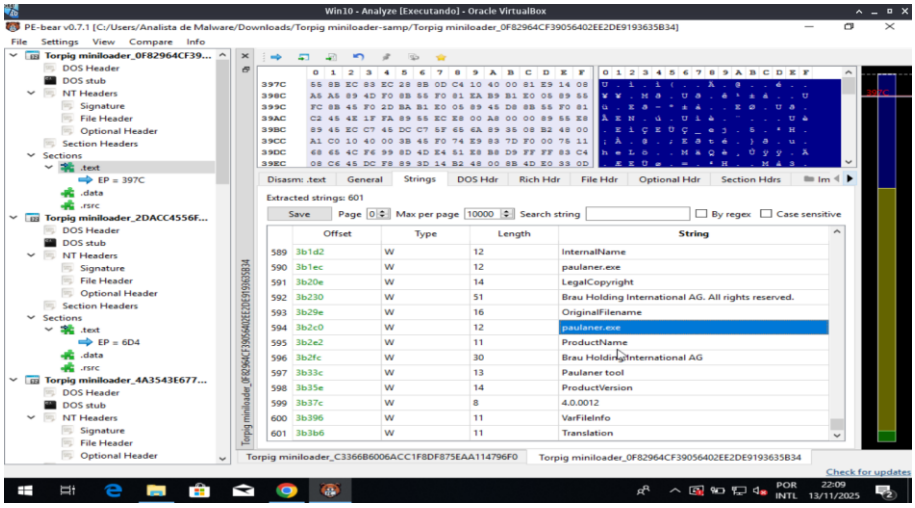


Keylogger



Keylogger

Arquivo .exe - Aqui revela o arquivo torpig está empregando um spoofing de metadados ao preencher seus campos (Version Info) com informações que se passem por um software legítimo(paulaner.exe).



Paulaner.exe

b. Análise estática

Durante a análise estática, foram identificados nove arquivos maliciosos: oito relacionados ao Torpig (atuando como carregadores/executores) e um arquivo adicional, encontrado após a execução, localizado em /ProgramData. Este último trata-se de uma DLL maliciosa denominada **lmbd.dll**.

Amostra 1 - 0F82964CF39056402EE2DE9193635B34

Hash256 -> 70484A2A2BA530D910CA3F3919B2E128579EDA1C4F55248D865412D85DDF15CF

File -> 242688 bytes

Tooling -> Visual Studio 2005

VirusTotal -> 66/72

Entropy -> 6.652

Format -> RSDS

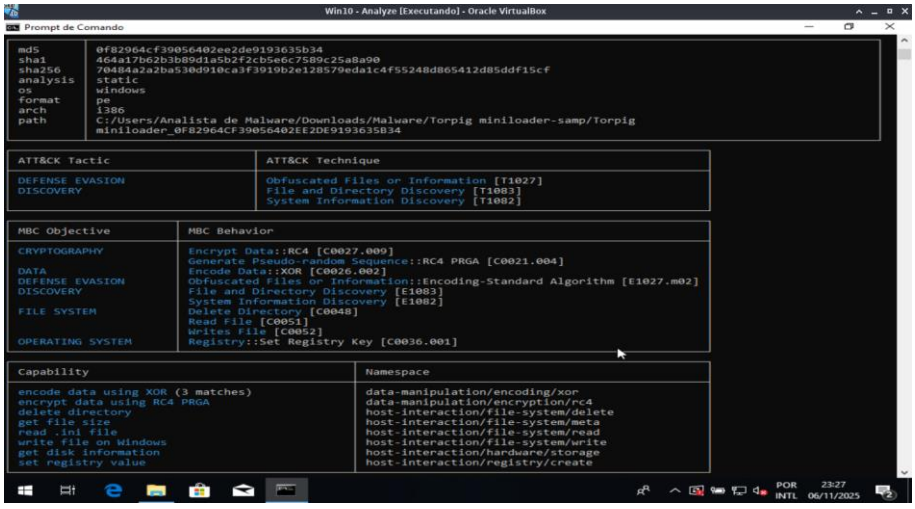
Name -> packaigee.pdb

32 bits -> suport

Library -> kernel32.dll, SHLWAPI.dll

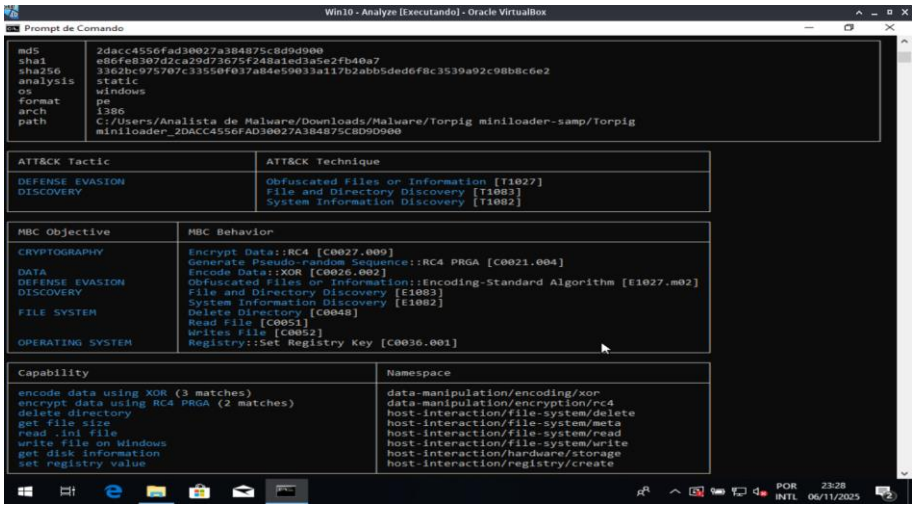
Technique -> T1112 | T1006 | T1055

Signature -> PE00



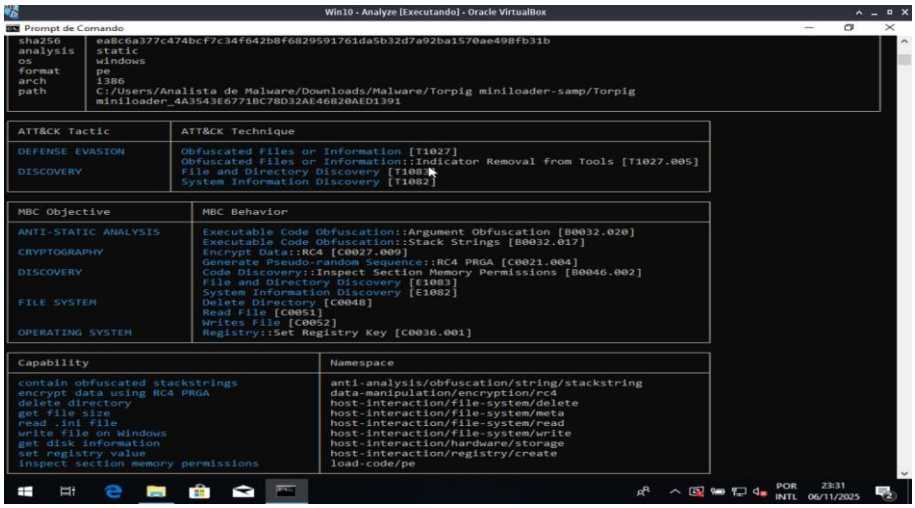
CAPA

Amostra 2 - 2DACC4556FAD30027A384875C8D9D900
Hash256 -> 3362BC975707C33550F037A84E59033A117B2ABB5DED6F8C3539A92C98B8C6E2
File -> 238080 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 65/72
Entropy -> 6.753
Format -> RSDS
Name -> catlashis.pdb
32 bits -> Suport
Library -> kernel32.dll, SHLWAPI.dll
Technique -> T1112 | T1006 | T1055
Signature -> PE00



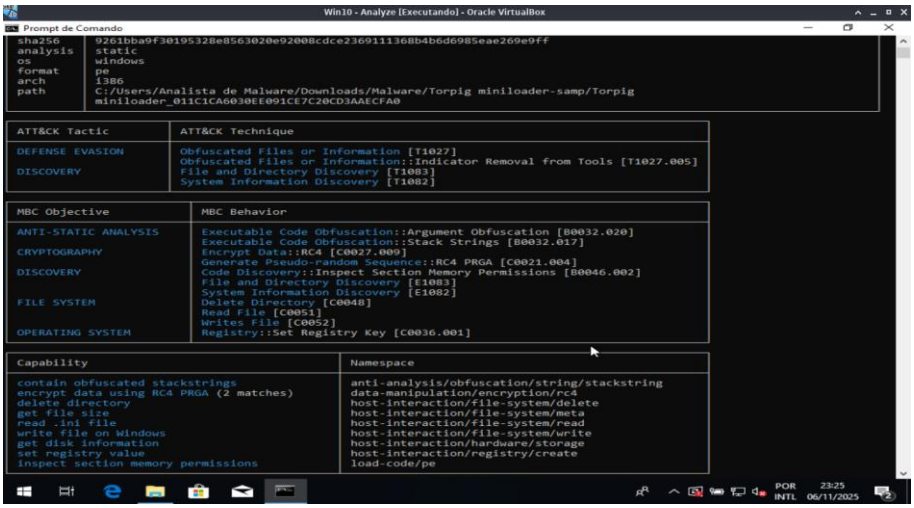
CAPA

Amostra 3 - 4A3543E6771BC78D32AE46820AED1391
Hash256 -> EA8C6A377C474BCF7C34F642B8F6829591761DA5B32D7A92BA1570AE498FB31B
File -> 241152 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 67/72
Entropy -> 6.708
Format -> RSDS
Name -> prieivatie.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00



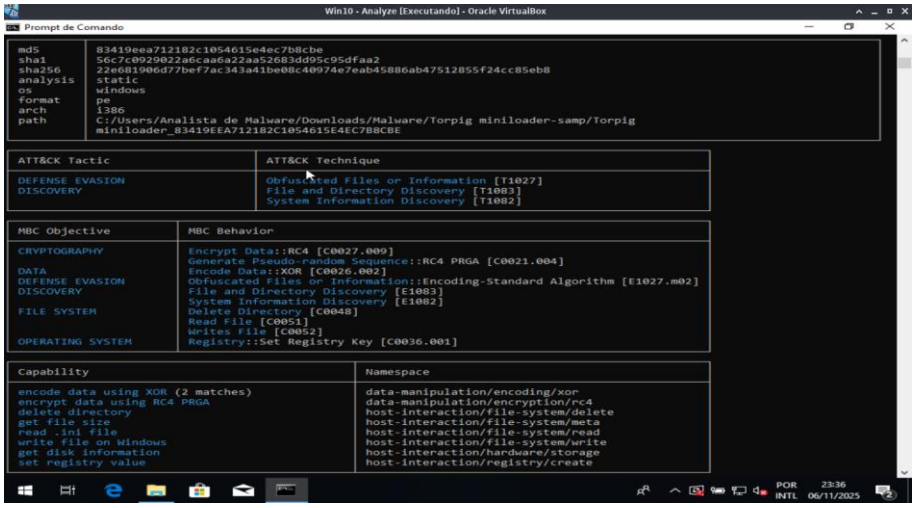
CAPA

Amostra 4 - 011C1CA6030EE091CE7C20CD3AAECFA0
Hash256 -> 9261BBA9F30195328E8563020E92008CDCE2369111368B4B6D6985EAE269E9FF
File -> 243712 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 66/72
Entropy -> 6.665
Format -> RSDS
Name -> piachakage.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00



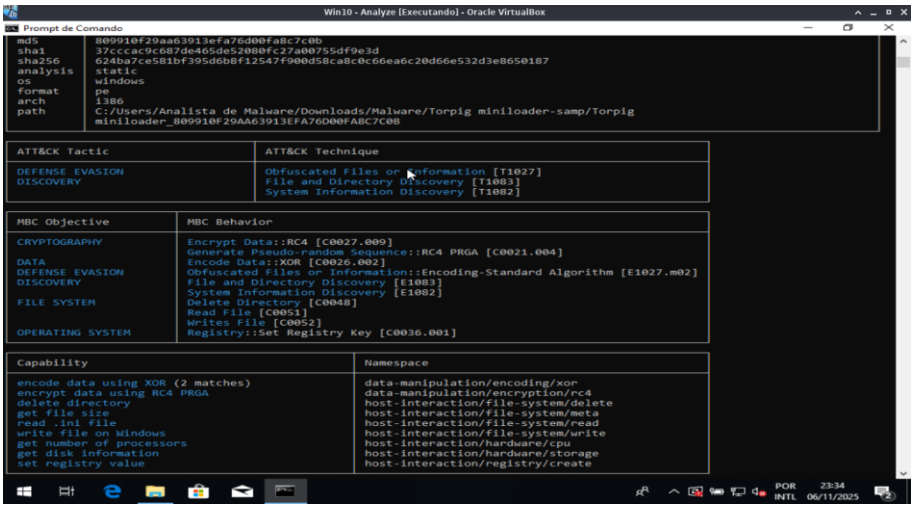
CAPA

Amostra 5 - 83419EEA712182C1054615E4EC7B8CBE
Hash256 -> 22E681906D77BEF7AC343A41BE08C40974E7EAB45886AB47512855F24CC85EB8
File -> 247808 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 66/72
Entropy -> 6.591
Format -> RSDS
Name -> nantietive.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00



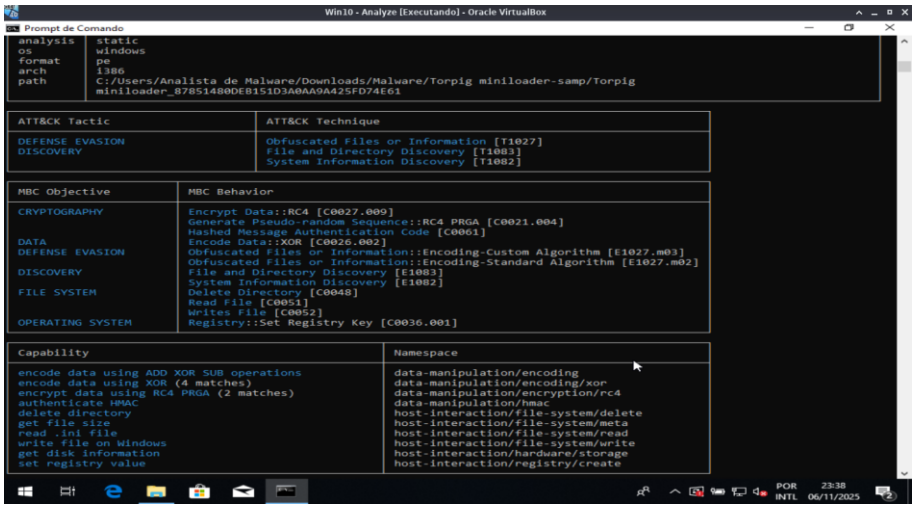
CAPA

Amostra 6 - 809910F29AA63913EFA76D00FA8C7C0B
Hash256 -> 624BA7CE581BF395D6B8F12547F900D58CA8C0C66EA6C20D66E532D3E8650187
File -> 242688 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 65/72
Entropy -> 242688 bytes
Format -> RSDS
Name -> naiotoivhe.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00



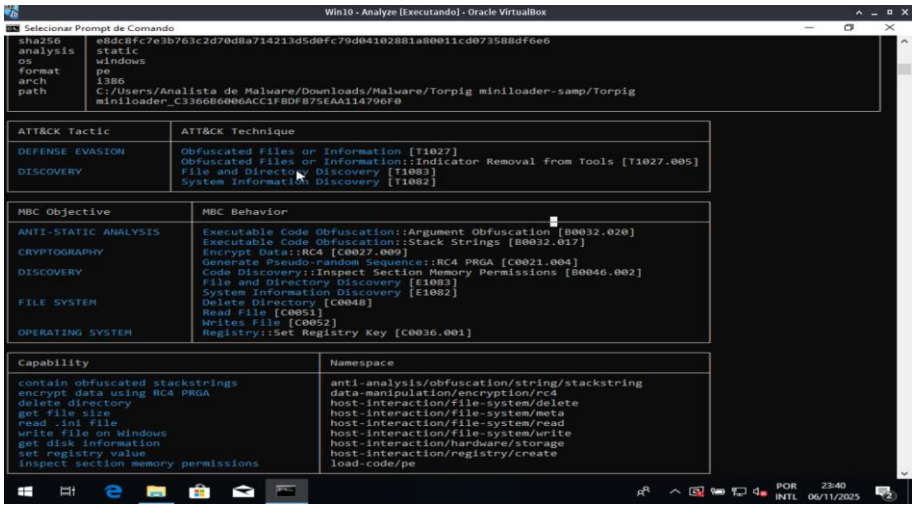
CAPA

Amostra 7 - 87851480DEB151D3A0AA9A425FD74E61
Hash256 -> 5F54E7CEA69962C932927DD3D71CEC1943539F1E13C1D84A971450D0FF109901
File -> 238080 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 66/72
Entropy -> 6.767
Format -> RSDS
Name -> intterfaece.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00



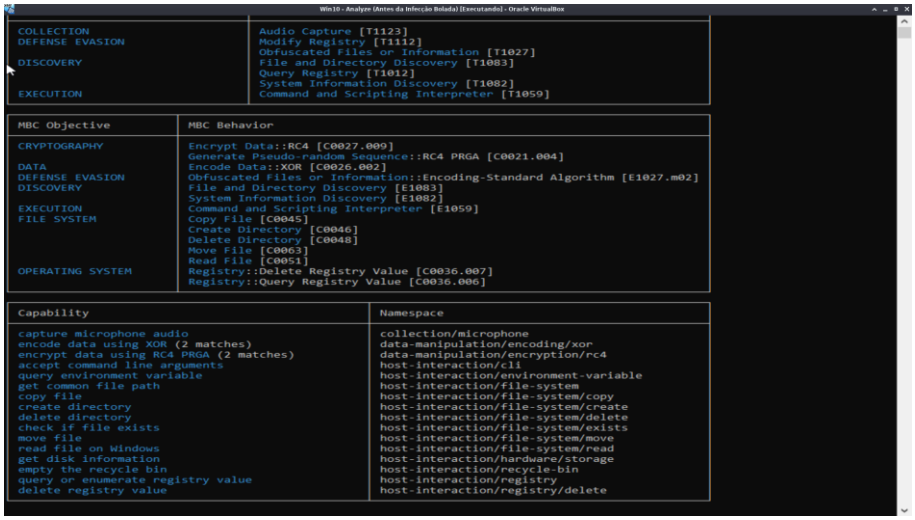
CAPA

Amostra 8 - C3366B6006ACC1F8DF875EAA114796F0
Hash256 -> E8DC8FC7E3B763C2D70D8A714213D5D0FC79D04102881A80011CD073588DF6E6
File -> 249344 bytes
Tooling -> Visual Studio 2005
VirusTotal -> 65/72
Entropy -> 6.572
Format -> RSDS
Name -> packaghe.pdb
32 bits -> suport
Library -> kernel32.dll, SHLWAPI.dll
Techinique -> T1112 | T1006 | T1055
Signature -> PE00

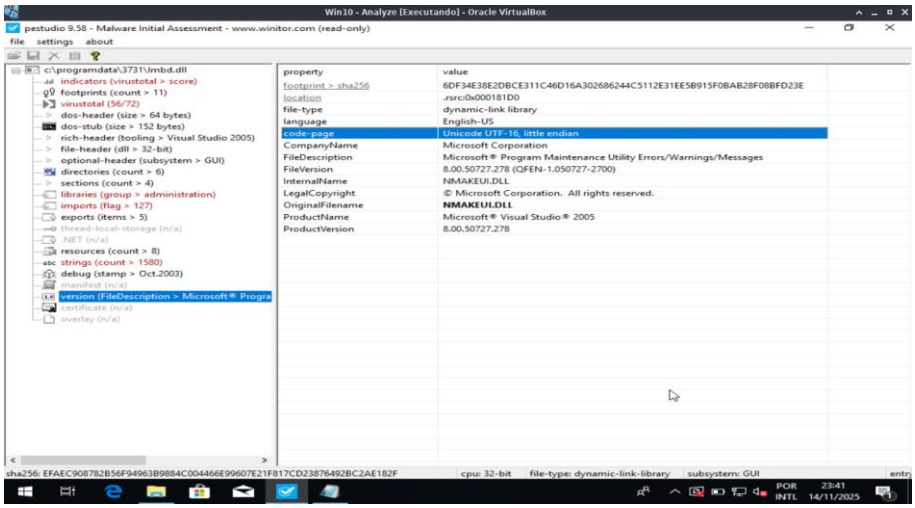


CAPA

Amostra 9 - lmbd.dll (Criada após execução do malware)
sha256 -EFAEC908782B56F94963B9884C004466E99607E21F817CD23876492BC2AE182F
file - 101888 bytes
entropy - 6.710
tooling - Visual Studio 2005
description - Microsoft® Program Maintenance Utility Errors/Warnings/Messages
version - NMAKEUI.DLL
MITRE - T1485 | T1105 | T1036 | T1006 | T1055 | T1134
Virus Total - 56/72
Format - RSDS
file-name - clateass.pdb
export - sezeiezfr.dll
DLLs - SHLWAPI.dll, kernel32.dll, ole32.dll, ADVAPI32.dll, SHELL32.dll e WINMM.dll



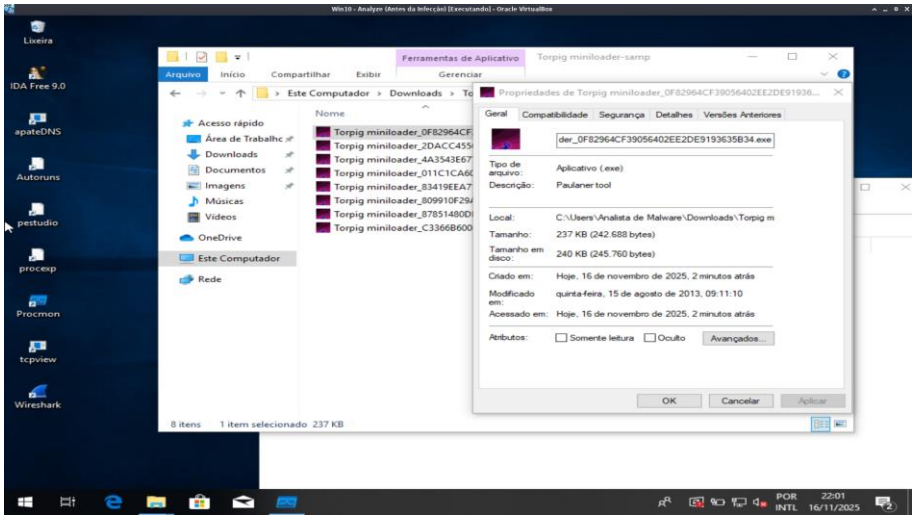
CAPA



c. Análise Dinâmica

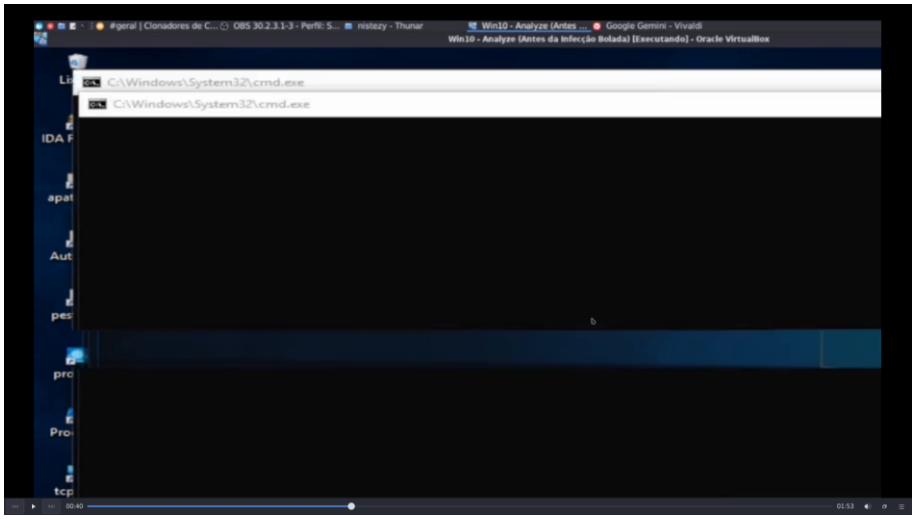
- **Método de inicialização/Após reinicialização**

Execução do Malware - Para iniciarmos o malware, foi necessário converter os arquivos Torpig em executáveis (.exe). De imediato, já foi possível notar algo incomum: o ícone do arquivo não se assemelhava aos ícones normalmente utilizados por executáveis legítimos.



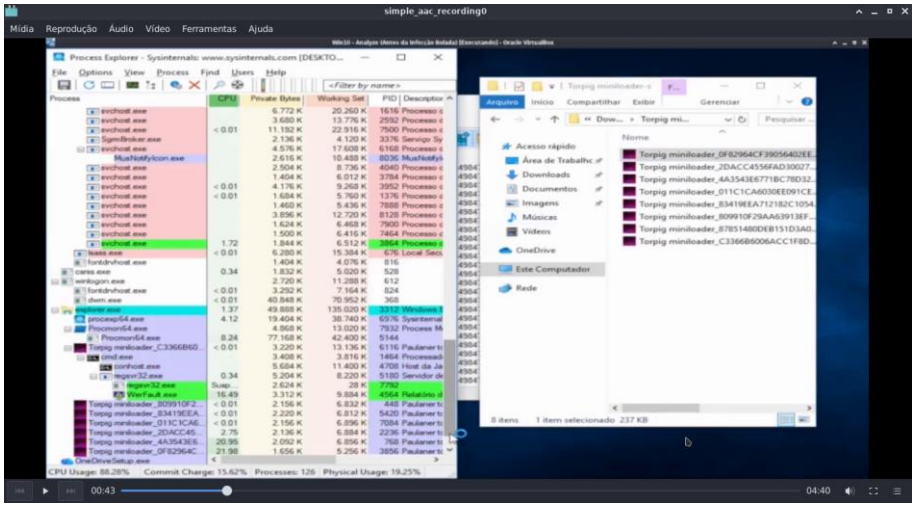
Torpig

Reinicialização - Após a reinicialização, foram identificadas duas instâncias do processo **cmd.exe** sendo abertas automaticamente, o que indica possível atividade maliciosa.



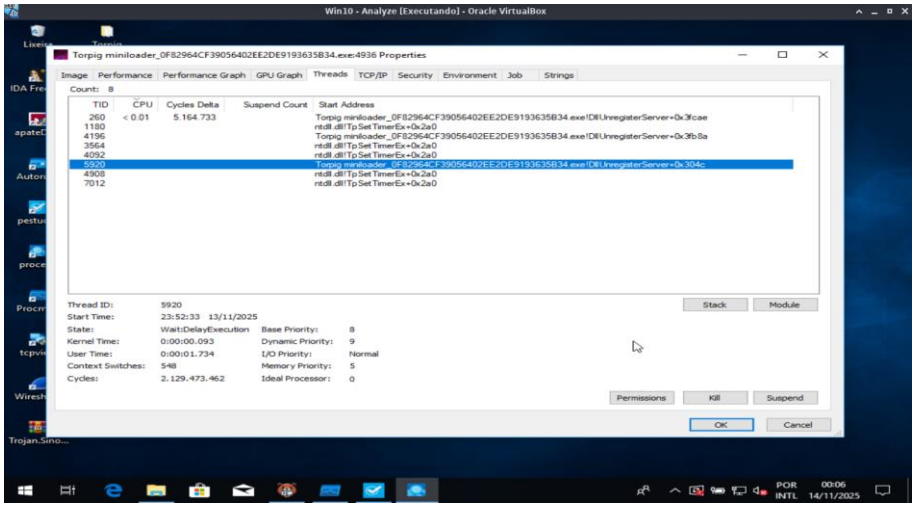
Após reinicialização

- **Atribuição dos processos do malware.**
  Processos - Ao analisar a árvore de processos associada ao Torpig, foi possível identificar quatro processos principais: cmd.exe → conhost.exe, regsvr32.exe → regsvr32.exe (processo filho espelhado) e WerFault.exe. Essa cadeia evidencia a utilização de componentes legítimos do sistema para mascarar a execução do malware.



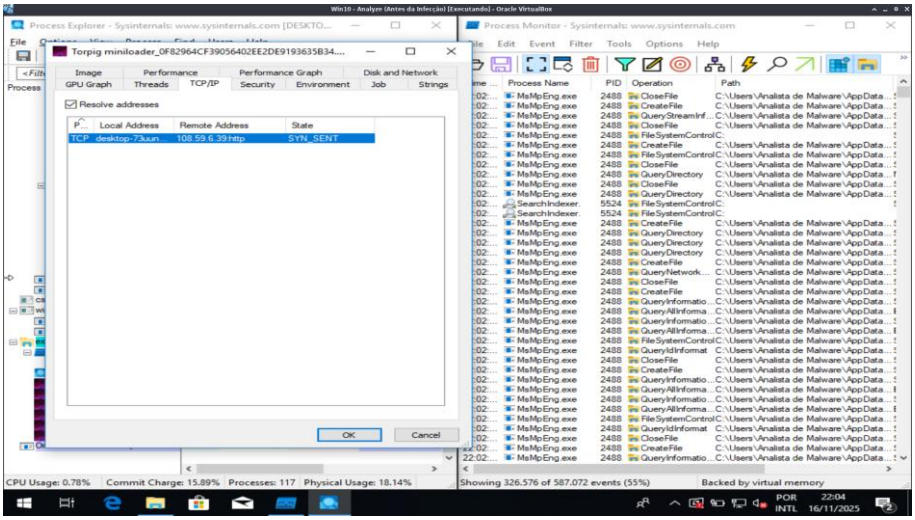
Process Monitor

Threads - As funções atribuídas a cada thread identificada são as seguintes:
Torpig miniloader_DF82964C …+0x1D1UnregisterServer-> Indica **execução direta do código malicioso**.
ntdll.dll!TpSetTimerEx+0x2a0 -> Mostra **manipulação de *timers*** do sistema.
Torpig miniloader_DF82964C …+0x3fb8a -> Indica **execução de rotinas específicas do Torpig**.
Torpig miniloader_DF82964C …+0x304c -> **Thread Principal e Ativa.** Semelhante ao item anterior, mas está *thread* é notável pelo alto consumo de **CPU.**



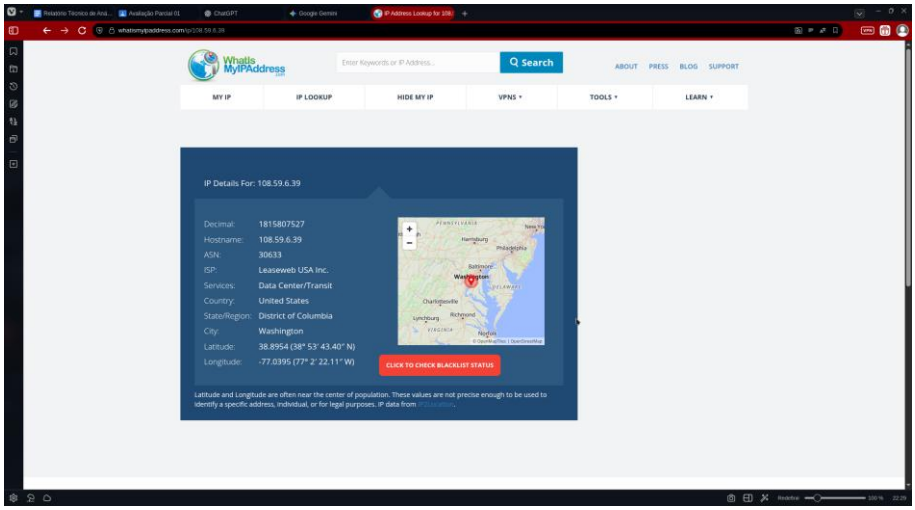
Threads

- **Interação com internet e rede**
  TCP/IP - É possível observar a geração de tráfego suspeito, incluindo o envio de pacotes em estado SYN_SENT para o endereço IP *108.59.6.39*:http.



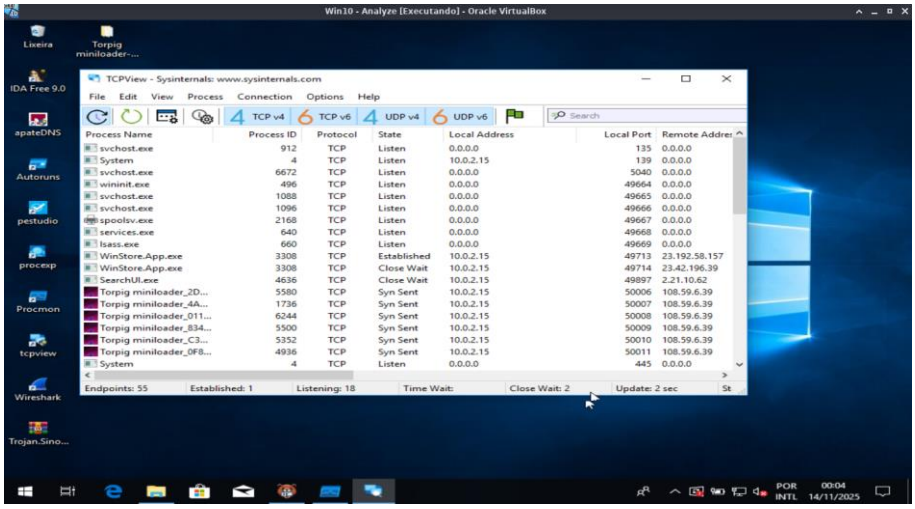
SYN_SENT

IP reverso - Após analisarmos as tentativas de conexão, foi possível realizar uma consulta de *reverse IP*, a qual retornou as seguintes informações:



IP reverso

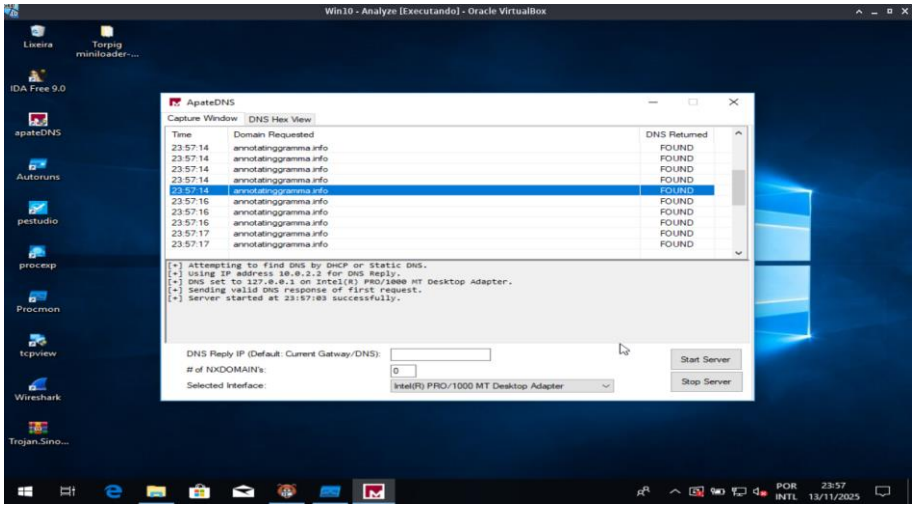
TCPView - Ao abrir o TCPView, é possível observar o mesmo IP (*108.59.6.39*) estabelecendo uma conexão reversa com a máquina infectada, evidenciando que o sistema passou a atuar como um **bot** controlado por um possível servidor de Comando e Controle (C2).



TCPView

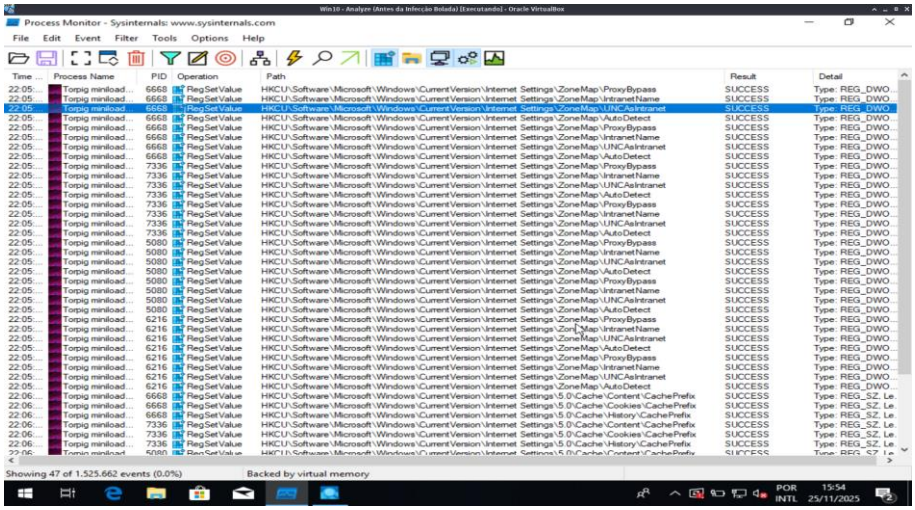
ApateDNS - Ao abrir o serviço do ApateDNS, é possível observar a resolução de um domínio suspeito (*annontatinggramma.info*). Em seguida, ao consultar

esse domínio no VirusTotal, verificam-se registros anteriores de detecção, indicando que ele já havia sido associado a atividades maliciosas.



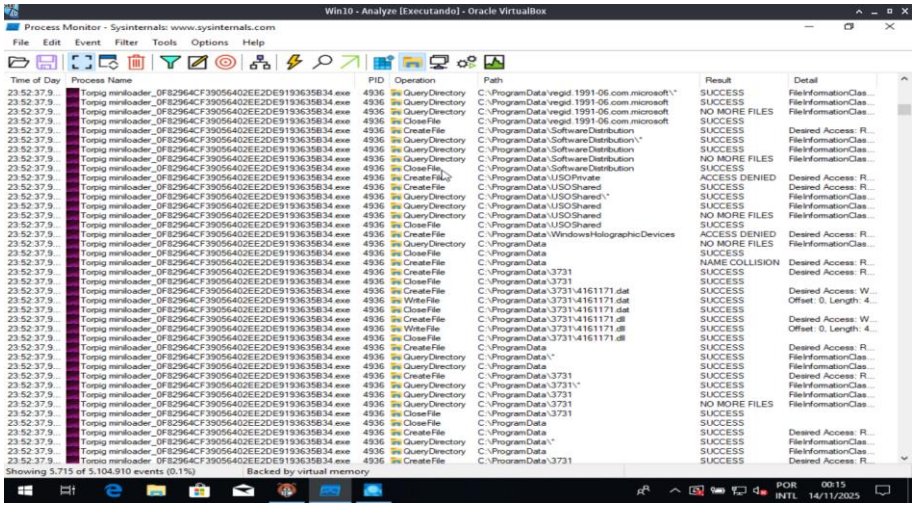
ApateDNS

- **Criação e alteração de registros, diretórios e arquivos.**
  RegeditInternet - O malware está alterando e sobrescrevendo as permissões de navegação e internet nas chaves do windows, possivelmente alterando as configurações de segurança:

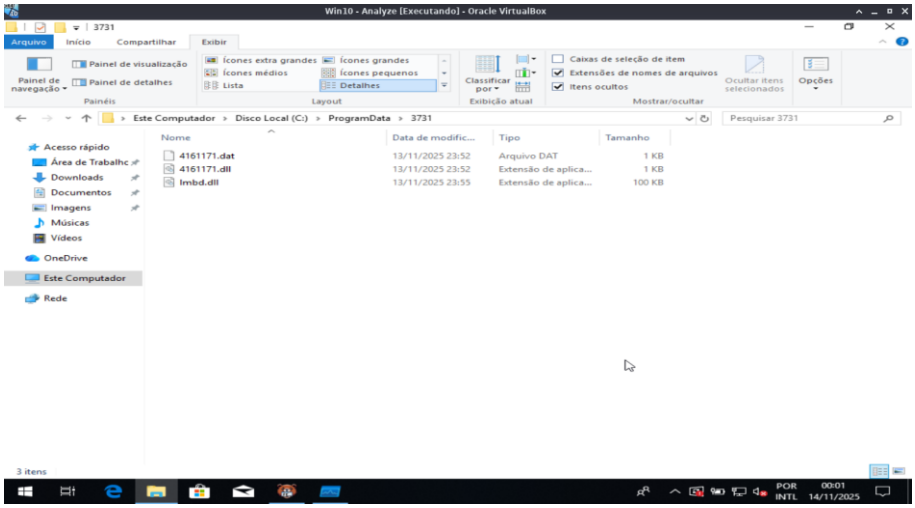


HKCU Zone

Pasta 3731 - Após a execução do malware podemos notar uma nova pasta dentro do /ProgramData que não havia antes sendo ela a /ProgramData/3731, onde dentro guardas três arquivos sendo um deles a Imdb.dll



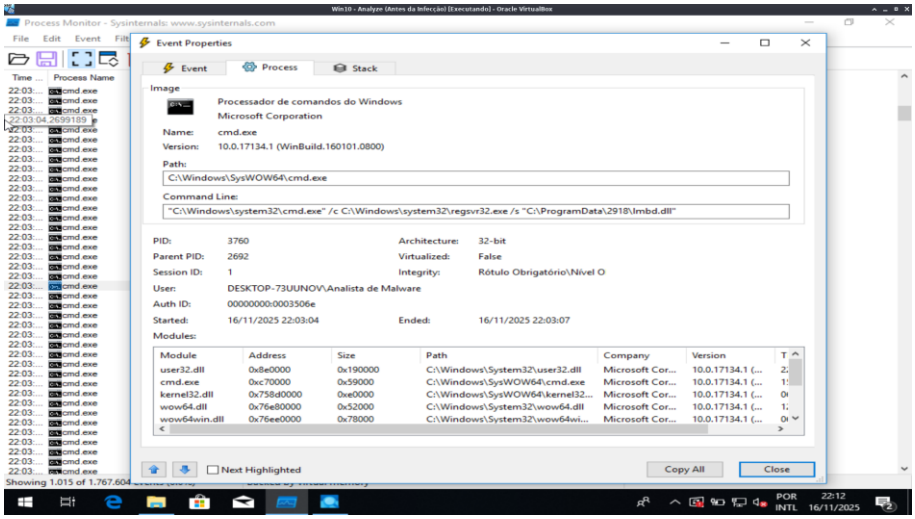
Criação da /3731



Pasta 3731

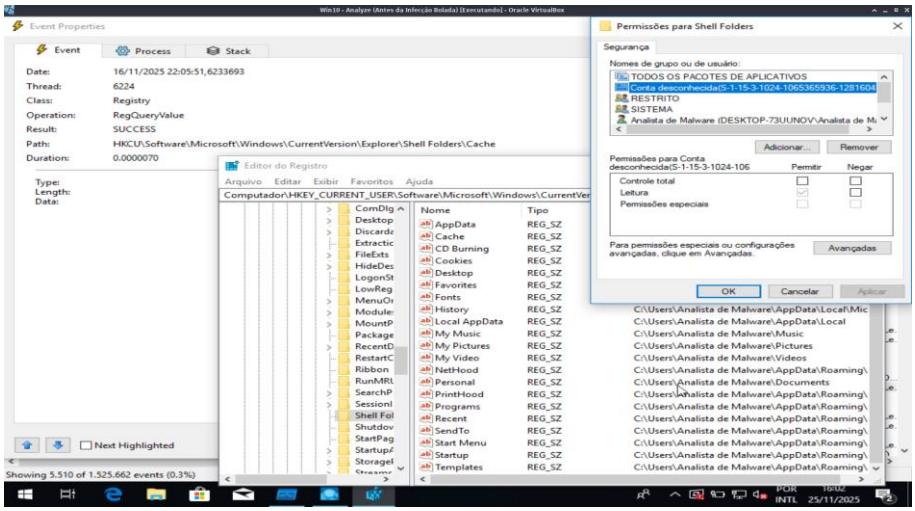
Criação do lmbd.dll - É possível identificar o uso dos softwares legítimos cmd.exe e regsvr32.exe, além de uma DLL criada pelo malware no diretório

/ProgramData. Essa DLL faz uso de diversas funções internas e depende de outras bibliotecas para executar suas rotinas maliciosas.



CMD Create lmbd.dll

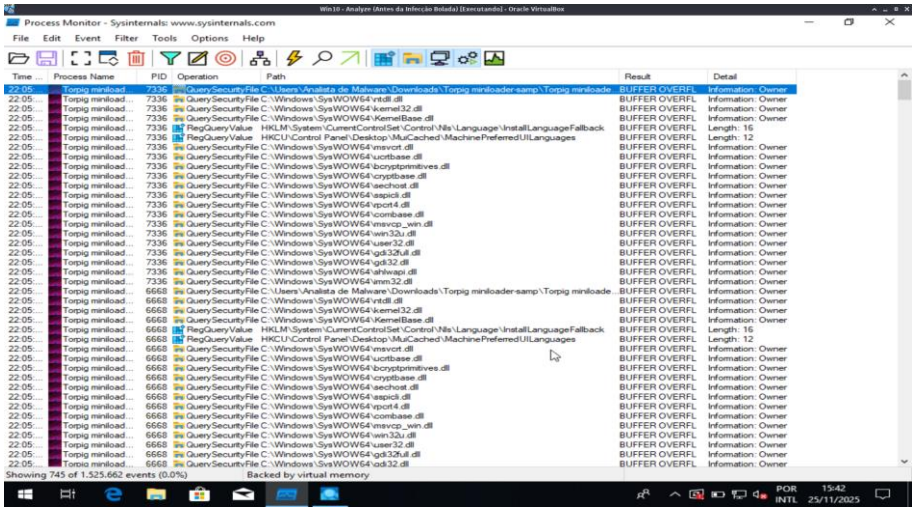
Permissão no Shell Folders - Na imagem é possível observar uma conta suspeita que, potencialmente associada ao malware Torpig, tentando alterar as permissões no registro referente a **Shell Folders**. Essa alteração poderia permitir ao malware escrever e executar arquivos em diretórios sensíveis, como o **ProgramData**.



Shell Folders

- **Exploração de Vulnerabilidade**

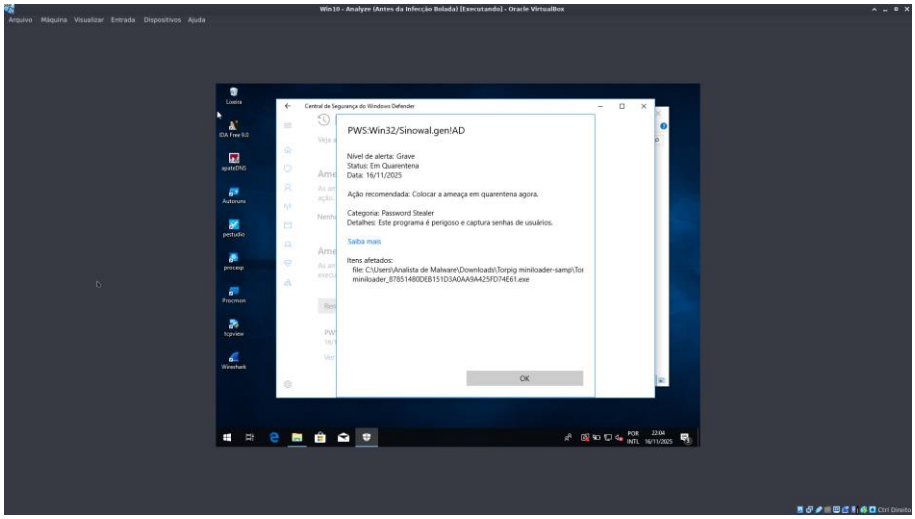
Buffer Overflow - O malware possivelmente está tentando realizar escalonamento de privilégios explorando uma vulnerabilidade do tipo **Buffer Overflow**. Indicando que o código malicioso pode estar sondando o sistema em busca de fragilidades específicas que permitam obter privilégios elevados (como conta *SYSTEM*).



Buffer Overflow

d. Assinatura

Assinatura da Windows Defender - Após a execução do malware o windows defender apitou mostrando a ameaça detectada como Torpig…, sendo um Password Steeling.



Assinatura do Windows Defender

6. MITRE ATT&CK

ID	Nome da Técnica	Contexto no Relatório e Observações
T1055	**Process Injection**	Identificada em **todas** as amostras analisadas (1 a 9). O malware injeta código em processos legítimos para evadir detecção.
T1006	**Direct Volume Access**	Presente em todas as amostras. Relaciona-se à capacidade de *rootkit* do malware para acessar ou manipular o sistema de arquivos diretamente, ocultando sua presença.
T1112	**Modify Registry**	Identificada nas amostras do carregador (amostra 1-8). O malware altera o registro para persistência e modificação de configurações de segurança.
T1036	**Masquerading**	Identificada na DLL maliciosa (lmbd.dll) e na análise de metadados. O arquivo finge ser legítimo preenchendo o "Version Info" com dados de softwares reais (ex: paulaner.exe) para enganar usuários e ferramentas.
T1027	**Obfuscated Files or Information**	Detectada na análise do CAPA/Ferramentas de análise. O malware utiliza ofuscação de arquivos e informações para dificultar a engenharia reversa.
T1082	**System Information Discovery**	O malware realiza o levantamento de informações sobre o sistema operacional infectado.
T1083	**File and Directory Discovery**	O malware varre o sistema em busca de arquivos e diretórios específicos, provavelmente para roubo de dados ou instalação.
T1105	**Ingress Tool Transfer**	Identificada especificamente na amostra 9 (lmbd.dll). Refere-se à transferência de ferramentas ou arquivos adicionais para o sistema comprometido.

T1134	**Access Token Manipulation**	Identificada na amostra 9 (lmbd.dll). O malware manipula tokens de acesso para operar com privilégios elevados ou personificar outros usuários.
T1485	**Data Destruction**	Listada na análise da amostra 9 (lmbd.dll). Pode indicar rotinas para destruir dados ou logs para dificultar a análise forense.

7. Impacto Potencial

- **Impacto Financeiro**
  - Roubo de credenciais
  - Fraude
  - perdas empresariais

- **Impacto na Segurança e Integridade**
  - Comprometimento do sistema
  - Evasão e persistência
  - Plataforma para maiores ameaças
- **Impacto Operacional e na Análise**
  - Custo de remediação
  - Dificuldade na investigação

8. Medidas de mitigação

- Controles de Integridade de Arquivos
- Configuração de Endpoint Hardening
- Proteção Avançada de Memória
- Definição de GPOs
- Políticas de Controle de Aplicativos
- Filtragem e Bloqueio de IP
- Autenticação de Múltiplos Fatores
- Uso de Máquinas Virtuais
- Treinamento Contínuo

9. Conclusão

A análise técnica do malware **Trojan Sinowal** confirmou a natureza altamente sofisticada e a arquitetura modular da ameaça, que se enquadrou na categoria de banking trojan.
Utilizando uma metodologia robusta combinando análise estática, engenharia reversa e dinâmica, a investigação revelou um forte foco em **evasão e persistência.**
Para mitigação desta ameaça, é necessário adoção de uma abordagem em camadas que vise a proteção de memória contra injeção de código, o bloqueio de C2 na rede e, crucialmente, a implementação de MFA.

10. Referências

- https://www.virustotal.com/gui/home/
- https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?Name=Trojan:DOS/Sinowal.L
- https://en.wikipedia.org/wiki/Torpig
- https://github.com/mandiant/capa
- https://github.com/hasherezade/pe-bear
- https://whatismyipaddress.com/ip-lookup